

MilestoneProof Beta Readiness Audit

What must be fixed before inviting external agency testers

Prepared for Anay Agarwalla | Production beta-readiness findings and release checklist

Release verdict

Not ready for external beta yet. MilestoneProof is strong enough for private demonstrations, but security, record integrity, retention, resumability, and mobile interaction defects should be corrected before outside agencies rely on it.

CURRENT
RELEASE

Blocked

External beta

CODE REVIEWED

a356ca1

Clean worktree

UNIT TESTS

**48
passed**

7 contracts + 41
web

Audit scope

This was a read-only walkthrough of the live production site and current codebase. It covered desktop and 320px layouts, public pages, legal pages, magic-link sign-in, intake, draft recovery, guided verification, a retained project, client evidence review, approval receipts, and the operator console. No application data or code was changed, and no additional Gemini or Cloudflare run was consumed.

Current flow health

Product flow	Status	Main reason
Landing and legal	BLOCKED	Operator identity and support address are unpublished
Sign-in and intake	NEEDS WORK	Pasted drafts survive, but uploaded files and account isolation do not
Criteria and verification	BLOCKED	Review-state integrity and runner network-security gaps
Resume and change requests	BLOCKED	Complete workspaces and approved states do not restore safely
Client evidence review	MOSTLY READY	Presentation is strong; stale reviews and expiring evidence remain unsafe
Receipts and operations	BLOCKED	Retention, legal holds, privacy processing, and print defects

1. Publish a qualified legal operator

The live Privacy Notice and Terms still state that the operator's legal identity and support address are pending and that external beta invitations must not begin in that state. Publish the actual adult or entity operating the service and a monitored support/privacy address.

Because the current product requires an 18+ retained-workflow attestation, an authorized adult must be the legal operator or account holder and handle real agreements, privacy requests, and client decisions. The existing retained approval bearing a minor's name should remain clearly identified as test data or be replaced with an adult-authorized test.

2. Close the authentication bypass

The repository enables anonymous Supabase authentication while unused legacy tables and storage policies allow authenticated users, including anonymous users, to write old product records or upload PDFs. Disable anonymous/public signup in production, remove or revoke the legacy schema and source bucket, and verify the live Supabase configuration.

Beta access must also be enforced after magic-link exchange. A removed tester can remain authenticated, be rejected by the dashboard API, and become trapped between login and dashboard redirects.

3. Enforce a safe record state machine

An old passing run or review link can currently act on a newer project state. The server must refuse new runs against IN_REVIEW or APPROVED records; create reviews only from the current last_run_id; require criteria revision, checks, and evidence to match; invalidate open review packets when criteria or verified evidence changes; and prevent a stale client decision from overwriting a newer record.

Reviews, receipts, and exports must use criteria_revision rather than the unchanged legacy revision value.

4. Protect drafts and client-review tokens

One global browser-storage entry currently contains the SOW, business information, verification settings, and sometimes a bearer-token review URL. It is not account-scoped and is not cleared on sign-out. Another agency using the same browser could inherit that information.

Namespace drafts by user and project, clear them on sign-out, and keep client bearer tokens out of global localStorage. Uploaded PDF drafts must also survive sign-in; only pasted text does today.

5. Finish runner network isolation

The verification worker blocks cross-origin top-level navigation but still permits off-origin scripts, images, frames, fetches, and XHR. DNS is validated without pinning the approved address to the browser connection. A tested page could probe internal resources or exploit DNS rebinding.

Constrain every request to the verified origin or a deliberately small allowlist, revalidate redirects and DNS at request time, and require unique locator matches rather than silently using the first matching element.

6. Make retention and legal holds reliable

A legal hold on a transaction does not currently protect its screenshot artifacts, while record deletion can remove an individually held artifact. Some deletion and job transitions can also complete before their required audit event.

Parent and artifact holds must both be honored. Deletion plus its audit record must be atomic. Queueing, leasing, job failure, retry, criteria revision, link revocation, and retention should receive the same transactional treatment.

7. Make projects genuinely resumable

The backend exposes workspace snapshots, but the interface does not save them. Cross-device resume reconstructs only part of the project and can lose the full source, edited rationale, mappings, progress, and review state.

An approved record also reopens in the wrong workflow phase. The approval destination is one global browser value, so one project can open another project's receipt. Persist and restore the complete workspace by record, including the current review link, decision, evidence, and receipt state.

8. Make privacy and operator workflows operational

The operator console tracks request status, owner, and notes, but it cannot verify a requester, locate their records, export them, correct them, delete them, apply a hold, or record the final response. Build or document a tested fulfillment process and maintain a durable log of each operator action.

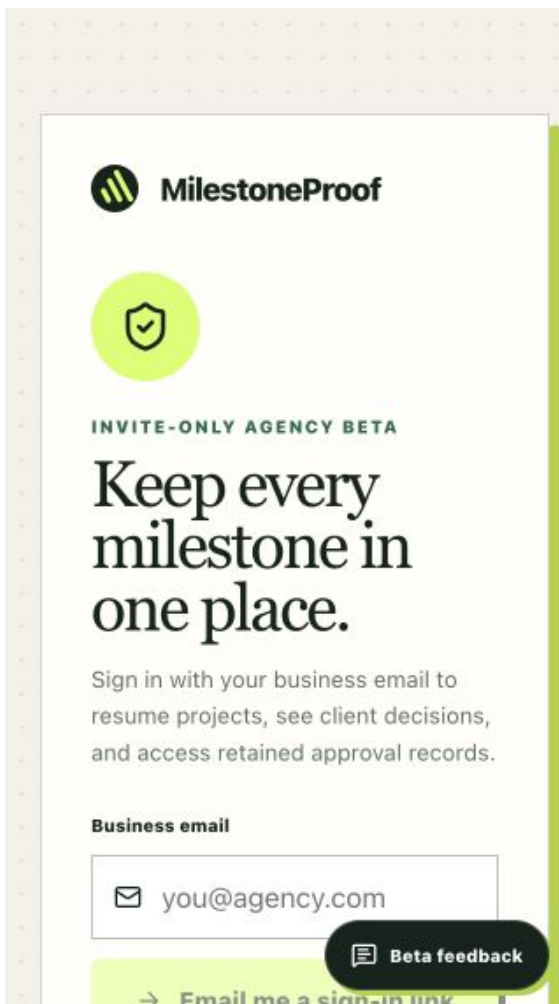
Retries need active-job, revision, and idempotency guards so they cannot repeat a form submission or overwrite an approved record. Notification insertion and delivery failures must also be recorded rather than disappearing.

Backend and product correctness before a broader beta

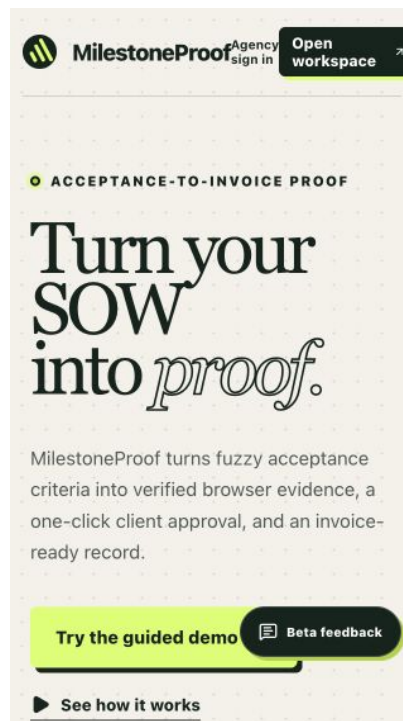
- Keep finalized receipts accessible after the original review packet expires.
- Refresh short-lived screenshot URLs while a client remains on the review page.
- Correct link and form checks containing query strings or URL fragments.
- Validate maximum business-field lengths before spending Gemini quota.
- Consume scarce runner capacity only after the request, ownership proof, mappings, and origin are valid.
- Fail closed or degrade safely when the rate-limit database is unavailable.
- Reject demo source mode on retained-run APIs so demos can never create legal records.
- Move the Acme test fixture away from /contact to an unmistakable fixture route.
- Update the dependency tree to resolve the reported moderate PostCSS security advisory.
- If a notification webhook is enabled, disclose its provider and the reviewer meta-data it receives.

Mobile and professional polish

- Reflow landing, dashboard, and operator headers at 320px and high zoom.
- Move or collapse the feedback trigger so it cannot cover landing, login, intake, or toast actions.
- Make the receipt toolbar wrap and long verified-target URLs break safely.
- Replace the visible Page 0 and validate true multi-page receipt pagination.
- Increase the size and readability of mobile workflow-step labels.



At 320px, the feedback trigger blocks the sign-in action.



The landing header and guided-demo CTA also collide at narrow widths.

Accessibility corrections

- Make the skip link target the actual focusable main content.
- Associate every verification-mapping error with its exact field using aria-invalid and aria-describedby.
- Add explicit Passed and Failed text to every verification result row.
- Move focus and announce successful client approvals through a live region.
- Move focus into the feedback success state after submission.
- Increase inactive workflow-step contrast and replace the 8px mobile label size.
- Correct remaining low-contrast sidebar, helper, divider, receipt, and step-number text.
- Increase small text actions, evidence summaries, and feedback controls toward 44 by 44 pixels.
- Extend forced-colors support to the outlined approval-limbo heading.

Testing and release operations

- Add real integration coverage for invitations, magic links, Gemini, origin verification, incomplete results, evidence integrity, stale reviews, decisions, change requests, receipts, exports, retention, legal holds, retries, and runner SSRF protection.
- Run one complete retained production transaction using an authorized adult reviewer.
- Verify that the retention cron and CRON_SECRET execute successfully.
- Verify backups and export recovery.
- Review every beta-allowlisted and administrator email address.
- Remove or clearly label current QA feedback, privacy requests, failed jobs, and retained test transactions before inviting agencies.

Release gate

Do not treat a green interface as a valid transaction unless the record, current criteria revision, passing run, evidence manifest, active review packet, decision, receipt, and audit chain all refer to the same immutable project state.

Validated strengths

The product does not need a visual restart. Its desktop identity, evidence presentation, legal-page styling, review experience, and receipt design are strong. The work should remain targeted.

- New real imports begin blank.
- Required business fields are checked before normal Gemini analysis.
- Pasted drafts survive sign-in.
- Criteria can be added, removed, duplicated, reordered, edited, and grounded in exact SOW quotations.
- The guided demo reliably completes both the failing and corrected verification runs.
- Job completion rejects missing results and mismatched evidence.
- Real screenshots are privately stored and individually hashed.
- Client review presents exact quotations, observed values, screenshots, and manifest hashes clearly.
- Currency cents and transaction-specific receipt metadata are preserved.
- Lint, typecheck, and all 48 current unit tests pass.
- No production application console errors were observed during the walkthrough.

[Skip to main content](#)

NORTHSTAR STUDIO SUBMITTED FOR APPROVAL

Spring launch

Acme Outdoors website - Evidence captured from launch-rc2

MILESTONE VALUE
\$12,000.00

What was promised—and what we observed

Every result below comes from the same verified staging run.

✓ ALL VERIFIED

RESULT

6 of 6 passed

VERIFIED

Jul 20, 2026, 6:24 PM PDT

WORLD

launch-rc2

SOURCE

Revision 1

Hero headline and CTA visibility

"The homepage hero headline and primary 'Plan my trip' call-to-action must be visible on load."

Expected: visible: true

Observed: visible: true

Inspect captured evidence and hashes



PASS: VERIFIED

CTA destination

"The primary call-to-action must take visitors to the contact page."

Expected: Activating the link opens same-origin /contact

Observed: /contact

Inspect captured evidence and hashes

PASS: VERIFIED

Services section content

"The services section must present three distinct trip-planning packages."

Expected: 3 matching elements

Observed: 3 matching elements

Inspect captured evidence and hashes

PASS: VERIFIED

Contact form submission

"Submitting the contact form must create a lead and show a success confirmation."

Expected: Success UI + HTTP 201

Observed: UI: shown; HTTP 201

Inspect captured evidence and hashes

PASS: VERIFIED

Form accessibility

"Required-field errors must be programmatically associated with their fields."

Expected: No critical or serious Axe violations

Observed: Axe completed: 0 non-blocking violations

Inspect captured evidence and hashes

PASS: VERIFIED

Mobile layout responsiveness

"The mobile navigation must fit a 390px viewport without horizontal scrolling."

Expected: < 1px horizontal overflow

Observed: 0px horizontal overflow

Inspect captured evidence and hashes

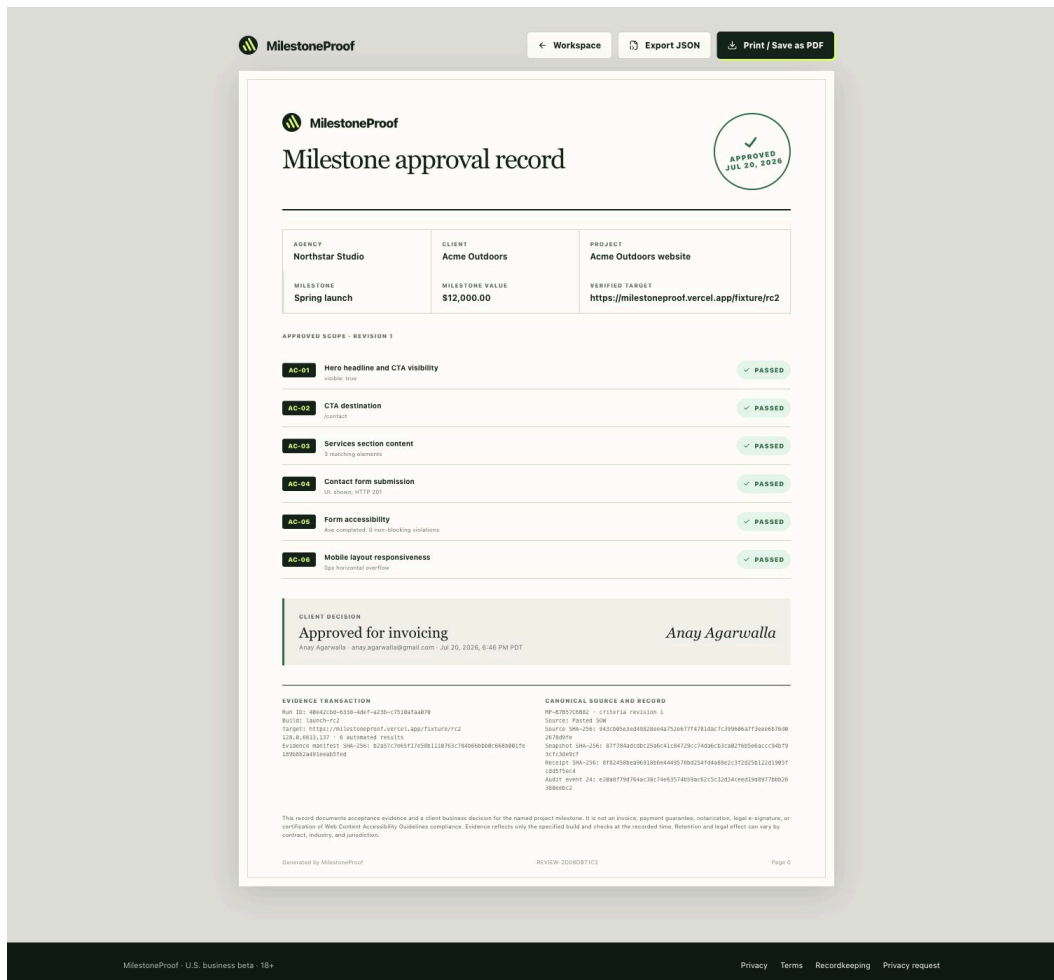
PASS: VERIFIED

Your decision is timestamped and bound to snapshot 88a657654d5... It is a business approval record, not a legal e-signature or payment guarantee.

Request changes

Approve milestone

Client evidence is the product's strongest completed experience: exact source context, observed values, screenshots, and cryptographic hashes are presented together.



The approval record is visually strong and transaction-specific, but the current screen footer exposes Page 0 and print pagination still needs validation.

Audit limitations

This audit deliberately avoided destructive or externally consequential actions. It did not submit a new real client decision, privacy request, feedback item, Gemini analysis, or Cloudflare verification job. The current automated suite is green but does not yet exercise the full retained production lifecycle or the security invariants listed in this report.

Recommended implementation order

1. Legal operator and production authentication configuration.
2. State-machine and review integrity.
3. Draft isolation and server-backed resume.
4. Runner egress security.
5. Retention, holds, audit atomicity, and operator fulfillment.
6. Mobile and accessibility corrections.
7. Full lifecycle regression testing and an adult-authorized retained production transaction.

External beta exit criteria

- Adult operator identity, monitored support address, Privacy Notice, and Terms are published.
- Anonymous access and unused legacy write paths are disabled and verified in production.
- Only the current immutable criteria revision and passing run can be reviewed or approved.
- Drafts, review links, receipts, and workspace snapshots are isolated by account and record.
- Runner egress, redirects, DNS resolution, legal holds, retention, and audit writes pass adversarial tests.
- Mobile, keyboard, screen-reader, and print defects in this report are closed.
- A complete adult-authorized production transaction and the full regression suite pass without manual repair.